

Security Management Practices

Overview of Security Management

- **Data Classification**

- Classification is part of a mandatory access control model to ensure that sensitive data is properly controlled and secured.
- Multi-level security policy has 4 classifications
 - Top secret
 - Secret
 - Confidential
 - Unclassified

- MAC data classification are categories:
 - Classification
 - Top secret
 - Confidential
- Change control & management
 - Why is change control & change management a security issue?
 - Many businesses live or die on data integrity
 - Modifying system breaks warranty

Information Classification Process

- Information wherever it is handled or stored from unauthorized access, modification, disclosure.
- Confidential data
 - Information that if disclosed, could:
 - Violate the privacy of individuals
 - Reduce the company's competitive advantage
 - Cause damage to the company
 - e.g. personnel records of individuals

- Information Handling

- Will help to identify standards and guideline to help safeguard information during its useful life.
- All confidential information must be clearly labeled with the word “confidential”.
- Information for which access has been authorized may only used for purposes identified to and authorized by the information owner.

Security Policy

- Management from all communities of interest must consider policies as the basis for all information security efforts
- Policies direct how issues should be addressed and technologies used
- Most difficult to implement
- Management defines security policy:
 - General or security program policy
 - Issue-specific security policies
 - Systems-specific security policies

Risk Management

- Risks can be identified & reduced, but never eliminated
- People are usually cheaper & easier to compromise than advance technological safeguards
- There are two different risk management
 - Qualitative : calculations are simple and readily understood and execute so no necessary to determine quantitative threat frequency & impact data
 - Quantitative: risk assessment & results are essentially subjective in both process & matrices.

Security Procedures and Guidelines

- Trust is a major principle underlying the development of security policies
- Initial step is to determine who gets access.
- Deciding on level of trust is a delicate balancing act.
- Too much trust may lead to eventual security problems

- Basic policy requirement
- Policies must:
 - be implementable and enforceable
 - be concise and easy to understand
 - balance protection with productivity
- Policies should:
 - state reasons why policy is needed
 - describe what is covered by the policies
 - define contacts and responsibilities
 - discuss how violations will be handled

Information Protection Policy

- Provides guidelines to users on the processing, storage and transmission of sensitive information.
- Main goal is to ensure information is appropriately protected from modification or disclosure.
- May be appropriate to have new employees sign policy as part of their initial orientation.
- Should define sensitivity levels of information